



Contoso Engineering (illustrative mock)

# Roadmap AI-SDLC G3

Proteger, entregar e fundações

|                     |            |
|---------------------|------------|
| DATA DO ASSESSMENT  | 2026-09-27 |
| VERSÃO DO FRAMEWORK | 2.0.1      |
| RESPONDENTES        | 14         |
| GERADO EM           | 2026-09-28 |

# G3: Proteger, entregar e fundações

| ID | DIMENSÃO                                         | SCORE | NÍVEL         | ALVO | GAP  | PRIORIDADE | HORIZONTE         |
|----|--------------------------------------------------|-------|---------------|------|------|------------|-------------------|
| D6 | Segurança e cadeia de suprimentos de IA          | 1,90  | L2 Adotando   | 3,00 | 1,10 | P2 Médio   | Semestre          |
| D7 | Entregar e operar                                | 1,75  | L2 Adotando   | 3,00 | 1,25 | P2 Médio   | Semestre          |
| D8 | Fundamentos de engenharia (amplificadores de IA) | 1,09  | L1 Explorando | 3,00 | 1,91 | P1 Alto    | Próximo trimestre |

## D6: Segurança e cadeia de suprimentos de IA

OWASP lista prompt injection (LLM01:2025), supply chain (LLM03:2025) e agência excessiva (LLM06:2025) entre os principais riscos [38], e agent goal hijack (ASI01) em primeiro lugar para aplicações agentic [39]; NIST SP 800-218A adiciona ao SSDF práticas para o desenvolvimento de modelos de IA [40].

**Baixa confiança: Mais de 30% das respostas são NA.**

### Comece por aqui

#### D6-Q5 AI supply chain (1,50, L1)

**Meta L3:** Um processo de review cobre componentes de IA; SBOMs e proveniência de build são produzidos para a maioria dos builds.

**Depois L4:** Proveniência é verificada no deploy (por exemplo metas de nível SLSA); componentes não avaliados são bloqueados automaticamente. [38][40][43][52]

#### D6-Q6 Threat modeling para features e agentes de IA (1,62, L2)

**Meta L3:** Threat models são exigidos para novas features de IA e workflows de agentes, e revisados por segurança.

**Depois L4:** Threat models são atualizados após incidentes e exercícios de red team; controles são verificados por testes automatizados. [38][39][40]

#### D6-Q4 Least privilege para agentes (1,71, L2)

**Meta L3:** Permissões de agentes são documentadas e revisadas; agentes não conseguem acessar credenciais de produção nem fazer push para protected branches.

**Depois L4:** Permissões são just-in-time e limitadas no tempo; o acesso é revisado automaticamente. [7][19][38][39]

### Estratégias recomendadas

- S6 Agentic Activation (P2 Médio, Semestre)
- S7 Security & Governance (P2 Médio, Semestre)

### Todas as perguntas desta dimensão

| ID    | PERGUNTA                                      | SCORE | N  | NA | EVIDÊNCIAS |
|-------|-----------------------------------------------|-------|----|----|------------|
| D6-Q1 | Scanning de base em todo repositório          | 2,00  | 7  | 7  | 4          |
| D6-Q2 | Remediação assistida por IA                   | 2,09  | 11 | 3  | 5          |
| D6-Q3 | Defesas contra prompt injection para agentes  | 2,25  | 8  | 6  | 6          |
| D6-Q4 | Least privilege para agentes                  | 1,71  | 7  | 7  | 3          |
| D6-Q5 | AI supply chain                               | 1,50  | 4  | 10 | 1          |
| D6-Q6 | Threat modeling para features e agentes de IA | 1,62  | 8  | 6  | 1          |
| D6-Q7 | Trilha de auditoria para ações de agentes     | 2,08  | 12 | 2  | 4          |

## D7: Entregar e operar

mais mudanças geradas por IA precisam de redes de segurança fortes na entrega [3], [5]; a Microsoft recomenda observação contínua da atividade de agentes [19] e está estendendo agentes para operações de cloud [22].

### Comece por aqui

#### D7-Q4 Observabilidade de agentes (1,57, L1)

**Meta L3:** Runs de agentes emitem telemetria para a stack central de observabilidade; dashboards mostram falhas e custo por agente.

**Depois L4:** Alertas disparam em drift de agentes, picos de erro ou anomalias de custo; achados alimentam governança (D1). [19][32][45]

#### D7-Q1 IA em pipelines CI/CD (1,69, L2)

**Meta L3:** Pipelines são code na maioria dos repositórios; análise de falhas assistida por IA está disponível para todas as equipes.

**Depois L4:** Agentes propõem correções e otimizações de pipeline automaticamente, sob review, com tempo de build e taxa de falhas rastreados. [16][17]

#### D7-Q3 Resposta a incidentes assistida por IA (1,71, L2)

**Meta L3:** Engenheiros de on-call na maioria das equipes usam IA para triage e resumos; revisões pós-incidente registram se a IA ajudou.

**Depois L4:** Agentes de operações executam diagnósticos aprovados automaticamente; tempo de restauração é comparado antes e depois da adoção. [16][17][22]

### Estratégias recomendadas

- S2 Foundry + SRE (P1 Alto, Próximo trimestre)
- S6 Agentic Activation (P2 Médio, Semestre)

### Todas as perguntas desta dimensão

| ID    | PERGUNTA                                    | SCORE | N  | NA | EVIDÊNCIAS |
|-------|---------------------------------------------|-------|----|----|------------|
| D7-Q1 | IA em pipelines CI/CD                       | 1,69  | 13 | 1  | 4          |
| D7-Q2 | Entrega progressiva e rollback              | 1,83  | 12 | 2  | 8          |
| D7-Q3 | Resposta a incidentes assistida por IA      | 1,71  | 14 | 0  | 6          |
| D7-Q4 | Observabilidade de agentes                  | 1,57  | 14 | 0  | 5          |
| D7-Q5 | Infrastructure as code com guardrails       | 1,85  | 13 | 1  | 7          |
| D7-Q6 | Automação operacional orientada por agentes | 1,86  | 14 | 0  | 6          |

## D8: Fundamentos de engenharia (amplificadores de IA)

DORA constata que essas capacidades amplificam os benefícios da adoção de IA, e que uma plataforma interna de alta qualidade se correlaciona com a capacidade de desbloquear valor de IA [1], [3].

### Comece por aqui

#### D8-Q7 Testes automatizados como sistema de controle (0,75, L0)

**Meta L3:** A maioria dos serviços tem testes automatizados em camadas que executam em todo PR dentro de time budgets acordados.

**Depois L4:** Suites de teste são ajustadas a partir de dados de defeitos escapados; tempo de feedback é rastreado e melhora. [3]

#### D8-Q4 Ecossistema de dados saudável (0,92, L1)

**Meta L3:** Dados-chave são catalogados com responsáveis e indicadores de qualidade; a maioria das perguntas pode ser respondida em até uma hora.

**Depois L4:** Qualidade de dados é monitorada automaticamente; linhagem e contratos existem para dados críticos. [1][2]

#### D8-Q5 Ambientes reproduzíveis para humanos e agentes (1,00, L1)

**Meta L3:** A maioria dos repositórios define um ambiente reproduzível; agentes usam a mesma definição.

**Depois L4:** Ambientes iniciam em minutos para qualquer repositório; drift em relação à definição é detectado. [8]

### Estratégias recomendadas

- S2 Foundry + SRE (P1 Alto, Próximo trimestre)
- S3 App Modernization (P1 Alto, Próximo trimestre)
- S1 GitHub Migration (P1 Alto, Próximo trimestre)

### Todas as perguntas desta dimensão

| ID    | PERGUNTA                                       | SCORE | N  | NA | EVIDÊNCIAS |
|-------|------------------------------------------------|-------|----|----|------------|
| D8-Q1 | Controle de versão para tudo                   | 1,07  | 14 | 0  | 8          |
| D8-Q2 | Frequência de commit e rollback rápido         | 1,23  | 13 | 1  | 3          |
| D8-Q3 | Plataforma interna de qualidade                | 1,29  | 14 | 0  | 5          |
| D8-Q4 | Ecossistema de dados saudável                  | 0,92  | 13 | 1  | 6          |
| D8-Q5 | Ambientes reproduzíveis para humanos e agentes | 1,00  | 14 | 0  | 2          |
| D8-Q6 | Documentação como contexto pronto para IA      | 1,36  | 14 | 0  | 8          |
| D8-Q7 | Testes automatizados como sistema de controle  | 0,75  | 12 | 2  | 9          |

## Referências

---

- [1] DORA. DORA AI Capabilities Model. Google Cloud, 2025. <https://dora.dev/ai/capabilities-model/report/>
- [2] DORA. DORA AI Capabilities Model: Survey Questions. Google Cloud, 2025. <https://dora.dev/ai/capabilities-model/questions/>
- [3] Google Cloud. Announcing the 2025 DORA Report: State of AI-Assisted Software Development. 2025. <https://cloud.google.com/blog/products/ai-machine-learning/announcing-the-2025-dora-report>
- [7] GitHub Docs. Risks and mitigations for GitHub Copilot cloud agent. <https://docs.github.com/en/enterprise-cloud@latest/copilot/concepts/security-governance-and-network-settings/risks-and-mitigations>
- [8] GitHub Docs. Best practices for using GitHub Copilot to work on tasks. <https://docs.github.com/en/enterprise-cloud@latest/copilot/tutorials/cloud-agent/get-the-best-results>
- [16] Microsoft Azure Blog. Agentic DevOps: Evolving software development with GitHub Copilot and Microsoft Azure. 2025. <https://azure.microsoft.com/en-us/blog/agentic-devops-evolving-software-development-with-github-copilot-and-microsoft-azure/>
- [17] Microsoft for Developers. Agentic DevOps in action: Reimagining every phase of the developer lifecycle. 2025. <https://developer.microsoft.com/blog/reimagining-every-phase-of-the-developer-lifecycle/>
- [19] Microsoft Learn. Govern and secure AI agents: Cloud Adoption Framework. <https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/ai-agents/governance-security-across-organization>
- [22] Microsoft Azure Blog. Announcing Azure Copilot agents and AI infrastructure innovations. 2025. <https://azure.microsoft.com/en-us/blog/announcing-azure-copilot-agents-and-ai-infrastructure-innovations/>
- [32] Gartner. Gartner Predicts AI Coding Costs Will Surpass Average Developer's Salary by 2028 as Token Consumption Surges. 2026-06-24. <https://www.gartner.com/en/newsroom/press-releases/2026-06-24-gartner-predicts-ai-coding-costs-will-surpass-average-developer-salary-by-2028-as-token-consumption-surges>
- [38] OWASP GenAI Security Project. OWASP Top 10 for LLM Applications 2025. <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>
- [39] OWASP GenAI Security Project. OWASP Top 10 for Agentic Applications for 2026. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- [40] NIST. SP 800-218A: Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile. 2024-07. <https://csrc.nist.gov/pubs/sp/800/218/a/final>
- [43] OpenSSF. SLSA: Supply-chain Levels for Software Artifacts. <https://slsa.dev/>
- [45] Liu, B., Qiu, H., Goiri, Í., Fonseca, R., Bianchini, R., Choukse, E. Agentic Coding in the Wild: Characterizing GitHub Copilot Traces at Production Scale. arXiv:2608.00101, 2026-07-30. <https://arxiv.org/abs/2608.00101>
- [52] Sakib, A. H. M. N., Banik, D., Jadhwal, M. Trust but Verify? Uncovering the Security Debt of Autonomous Coding Agents. arXiv:2607.12428, 2026-07-14. <https://arxiv.org/abs/2607.12428>